

# Contents

|          |                                                                   |           |
|----------|-------------------------------------------------------------------|-----------|
| <b>1</b> | <b>Introduction</b>                                               | <b>1</b>  |
| <b>2</b> | <b>Fundamentals</b>                                               | <b>2</b>  |
| 2.1      | Industrial Gateways in IT/OT Environments . . . . .               | 2         |
| 2.1.1    | Fundamentals of Industrial Gateways . . . . .                     | 2         |
| 2.1.2    | IT/OT Interfaces . . . . .                                        | 3         |
| 2.1.3    | Attack Surface and Asset Identification . . . . .                 | 5         |
| 2.2      | Regulatory and Standardization Framework . . . . .                | 6         |
| 2.2.1    | Regulation (EU) 2023/1230 . . . . .                               | 6         |
| 2.2.2    | prEN 50742 . . . . .                                              | 8         |
| 2.2.3    | EN IEC 62443 Series . . . . .                                     | 9         |
| 2.3      | Cybersecurity Fundamentals . . . . .                              | 12        |
| 2.3.1    | Security Goals . . . . .                                          | 12        |
| 2.3.2    | Threats, Vulnerabilities and Attack Vectors . . . . .             | 13        |
| 2.4      | Risk-Based Security Engineering . . . . .                         | 15        |
| 2.4.1    | Threat Analysis and Risk Assessment (TARA) . . . . .              | 15        |
| 2.4.2    | STRIDE Methodology . . . . .                                      | 16        |
| 2.4.3    | Risk Evaluation . . . . .                                         | 17        |
| 2.4.4    | Risk Treatment Strategies . . . . .                               | 18        |
| 2.5      | Security Testing Approaches . . . . .                             | 20        |
| 2.5.1    | Testing Methodologies . . . . .                                   | 20        |
| 2.5.2    | Static and Dynamic Analysis . . . . .                             | 21        |
| 2.5.3    | Vulnerability Assessment, Robustness, and Penetration Testing . . | 22        |
| <b>3</b> | <b>Methodology</b>                                                | <b>24</b> |
| 3.1      | Research Methodology . . . . .                                    | 24        |
| 3.2      | Derivation of Security Requirements . . . . .                     | 24        |
| 3.3      | Functional Security Testing Framework Architecture . . . . .      | 24        |
| 3.3.1    | Scope . . . . .                                                   | 25        |
| 3.3.2    | Traceability Model . . . . .                                      | 25        |
| 3.3.3    | Test Case Taxonomy . . . . .                                      | 26        |

|          |                                                       |           |
|----------|-------------------------------------------------------|-----------|
| 3.3.4    | Verification Life-cycle . . . . .                     | 26        |
| 3.4      | Evaluation Metrics . . . . .                          | 26        |
| <b>4</b> | <b>Implementation, Results, and Evaluation</b>        | <b>27</b> |
| 4.1      | Testbed Setup and Target Specification . . . . .      | 28        |
| 4.1.1    | Test Object . . . . .                                 | 28        |
| 4.1.2    | Test Setup . . . . .                                  | 28        |
| 4.1.3    | Toolchain Integration . . . . .                       | 28        |
| 4.2      | Application of the Testing Methodology . . . . .      | 28        |
| 4.2.1    | Authentication Tests . . . . .                        | 28        |
| 4.2.2    | Authorization Tests . . . . .                         | 28        |
| 4.2.3    | Configuration Tests . . . . .                         | 28        |
| 4.2.4    | Firmware and Update Protection Tests . . . . .        | 28        |
| 4.2.5    | Logging and Traceability Tests . . . . .              | 28        |
| 4.2.6    | Communication Security Tests . . . . .                | 28        |
| 4.3      | Empirical Results and Compliance Evaluation . . . . . | 28        |
| 4.3.1    | Test Results Overview . . . . .                       | 28        |
| 4.3.2    | Evaluation of Mitigation Effectiveness . . . . .      | 28        |
| 4.3.3    | MVO Compliance Verification . . . . .                 | 28        |
| <b>5</b> | <b>Summary and Outlook</b>                            | <b>29</b> |
| 5.1      | Summary of Findings . . . . .                         | 29        |
| 5.2      | Future Work . . . . .                                 | 29        |
|          | <b>Bibliography</b>                                   | <b>30</b> |
|          | <b>List of Figures</b>                                | <b>34</b> |
|          | <b>List of Tables</b>                                 | <b>35</b> |
|          | <b>A Note on the Use of Artificial Intelligence</b>   | <b>36</b> |